

Матриця та аналіз відповідності активів міжнародним стандартам

ISO 55000 | ISO 27001 | NIST CSF

1. Вступ

ТОВ "ТехноЛогіс" — українська ІТ-компанія середнього розміру, що спеціалізується на розробці програмного забезпечення та наданні послуг хмарної інфраструктури корпоративним клієнтам. Організація налічує 120 співробітників, має власний датацентр, розгалужену корпоративну мережу та обробляє персональні дані тисяч кінцевих користувачів.

Аналіз відповідності активів міжнародним стандартам є критично важливим для організації з кількох причин: по-перше, це дозволяє систематизувати управління різнорідними активами в єдиній методологічній рамці; по-друге, забезпечує виконання регуляторних вимог і підвищує довіру клієнтів та партнерів; по-третє, допомагає ідентифікувати прогалини у захисті та управлінні активами ще до виникнення інцидентів.

У цьому звіті досліджуються три стандарти: ISO 55000 (управління активами), ISO 27001 (управління інформаційною безпекою) та NIST Cybersecurity Framework (захист цифрових активів). Для кожного активу визначено рівень відповідності та обґрунтовано вибір найбільш релевантного стандарту.

2. Матриця відповідності

Нижче наведено матрицю відповідності активів ТОВ "ТехноЛогіс" вимогам стандартів ISO 55000, ISO 27001 та NIST CSF. Оцінювання здійснювалося за трьома рівнями: «Відповідає повністю» (наявні всі необхідні процедури та документація), «Відповідає частково» (частина вимог реалізована), «Не відповідає» (вимоги відсутні або ігноруються). Позначка «Не застосовується» вказує на відсутність суттєвого зв'язку між активом та конкретним стандартом.

Актив	Тип активу	ISO 55000	ISO 27001	NIST CSF
Сервери (фізичні)	Апаратне забезпечення	Відповідає повністю	Відповідає частково	Відповідає частково
Робочі станції	Апаратне забезпечення	Відповідає повністю	Відповідає частково	Відповідає частково
Мережеве обладнання (маршрутизатори, комутатори)	Апаратне забезпечення	Відповідає повністю	Відповідає частково	Відповідає повністю
Джерела безперебійного живлення (ДБЖ)	Інфраструктура	Відповідає повністю	Не застосовується	Відповідає частково
Системи відеоспостереження	Інфраструктура	Відповідає повністю	Відповідає частково	Відповідає частково
База даних клієнтів	Дані / Інформація	Відповідає частково	Відповідає повністю	Відповідає повністю

Актив	Тип активу	ISO 55000	ISO 27001	NIST CSF
Фінансові записи та звіти	Дані / Інформація	Відповідає частково	Відповідає повністю	Відповідає повністю
Резервні копії даних	Дані / Інформація	Відповідає частково	Відповідає повністю	Відповідає повністю
ERP-система (1C, SAP)	Програмне забезпечення	Відповідає частково	Відповідає повністю	Відповідає повністю
Антивірусне ПЗ	Програмне забезпечення	Не відповідає	Відповідає повністю	Відповідає повністю
Операційні системи	Програмне забезпечення	Відповідає частково	Відповідає повністю	Відповідає повністю
Корпоративна мережа (LAN/WAN)	Мережеві ресурси	Відповідає частково	Відповідає повністю	Відповідає повністю
VPN-інфраструктура	Мережеві ресурси	Не застосовується	Відповідає повністю	Відповідає повністю
Хмарні сховища (AWS, Azure)	Мережеві ресурси	Відповідає частково	Відповідає повністю	Відповідає повністю
Банківські рахунки / кредитні лінії	Фінансові активи	Відповідає повністю	Відповідає частково	Не застосовується
Ліцензії та патенти	Нематеріальні активи	Відповідає повністю	Відповідає частково	Не застосовується
Персонал (кваліфікація)	Людські ресурси	Відповідає повністю	Відповідає частково	Відповідає частково

Відповідає повністю	Відповідає частково	Не відповідає	Не застосовується	— умовні позначення матриці відповідності
---------------------	---------------------	---------------	-------------------	---

3. Аналіз відповідності

Нижче наведено детальний аналіз за кожною категорією активів із поясненням, чому ті чи інші стандарти є найбільш релевантними.

1. Апаратне забезпечення та інфраструктура

Сервери, робочі станції, мережеве обладнання та інфраструктурні об'єкти найбільш повно охоплюються стандартом ISO 55000, оскільки цей стандарт регулює весь життєвий цикл фізичних активів: від придбання та введення в експлуатацію до технічного обслуговування та утилізації. ISO 27001 застосовується частково — переважно в частині фізичного захисту серверних приміщень та контролю доступу до обладнання (Додаток А.11). NIST CSF забезпечує виявлення аномалій на рівні мережевого трафіку та реагування на інциденти (функції Detect та Respond).

2. Інформаційні дані

Бази даних клієнтів, фінансові записи та резервні копії є ключовими об'єктами регулювання стандарту ISO 27001, який вимагає забезпечення конфіденційності, цілісності та доступності інформації (принцип CIA-тріади). NIST CSF доповнює цей підхід через структуровану систему управління ризиками та відновлення після інцидентів (функція Recover). ISO 55000 застосовується лише частково — в контексті оцінки цінності інформаційних активів та планування їх тривалого зберігання.

3. Програмне забезпечення

Управлінські системи (ERP), засоби захисту та операційні системи регулюються переважно ISO 27001 (управління доступом, оновлення ПЗ, моніторинг) та NIST CSF (ідентифікація вразливостей, захист від загроз). ISO 55000 відіграє меншу роль, проте може застосовуватися для планування ліцензійного циклу та модернізації програмних активів.

4. Мережеві ресурси

Корпоративна мережа, VPN та хмарні сховища є критичними об'єктами для NIST CSF, який акцентує увагу на захисті периметру, сегрегації мереж та моніторингу трафіку. ISO 27001 забезпечує управлінський аспект — розробку політик безпеки мережі та процедур контролю доступу. ISO 55000 для суто мережевих ресурсів має обмежену застосовність.

5. Фінансові та нематеріальні активи

Банківські рахунки, ліцензії та патенти підпадають під регулювання ISO 55000 у частині оцінки вартості активів, обліку та управління їхнім портфелем. ISO 27001 доречний для захисту фінансової документації від несанкціонованого доступу. NIST CSF до суто фінансових активів застосовується в обмеженому обсязі.

6. Людські ресурси

Компетенції персоналу регулюються ISO 55000 через вимоги до кваліфікації фахівців з управління активами. ISO 27001 встановлює вимоги до навчання персоналу з питань інформаційної безпеки (розділ 7.2 та A.7). NIST CSF враховує людський фактор у контексті ролей та відповідальності при реагуванні на інциденти.

4. Висновки

Проведений аналіз свідчить про те, що жоден зі стандартів не є універсальним для всього портфеля активів ТОВ "ТехноLogic". Оптимальна стратегія передбачає інтегроване застосування всіх трьох стандартів:

ISO 55000 — основа для управління фізичними, фінансовими та нематеріальними активами протягом усього їх життєвого циклу.

ISO 27001 — обов'язковий стандарт для захисту всіх категорій інформаційних активів, особливо персональних і фінансових даних.

NIST CSF — практична система для управління кіберризиками, що доповнює ISO 27001 конкретними технічними контролями та процедурами реагування.

Рекомендується розробити інтегровану програму відповідності, яка синхронізує вимоги всіх трьох стандартів, уникаючи дублювання зусиль та забезпечуючи комплексний захист активів організації.